Bank Service Threat Model

Owner: Svetlana Golub
Reviewer:
Contributors:
Date Generated: Sat Sep 05 2026

Executive Summary

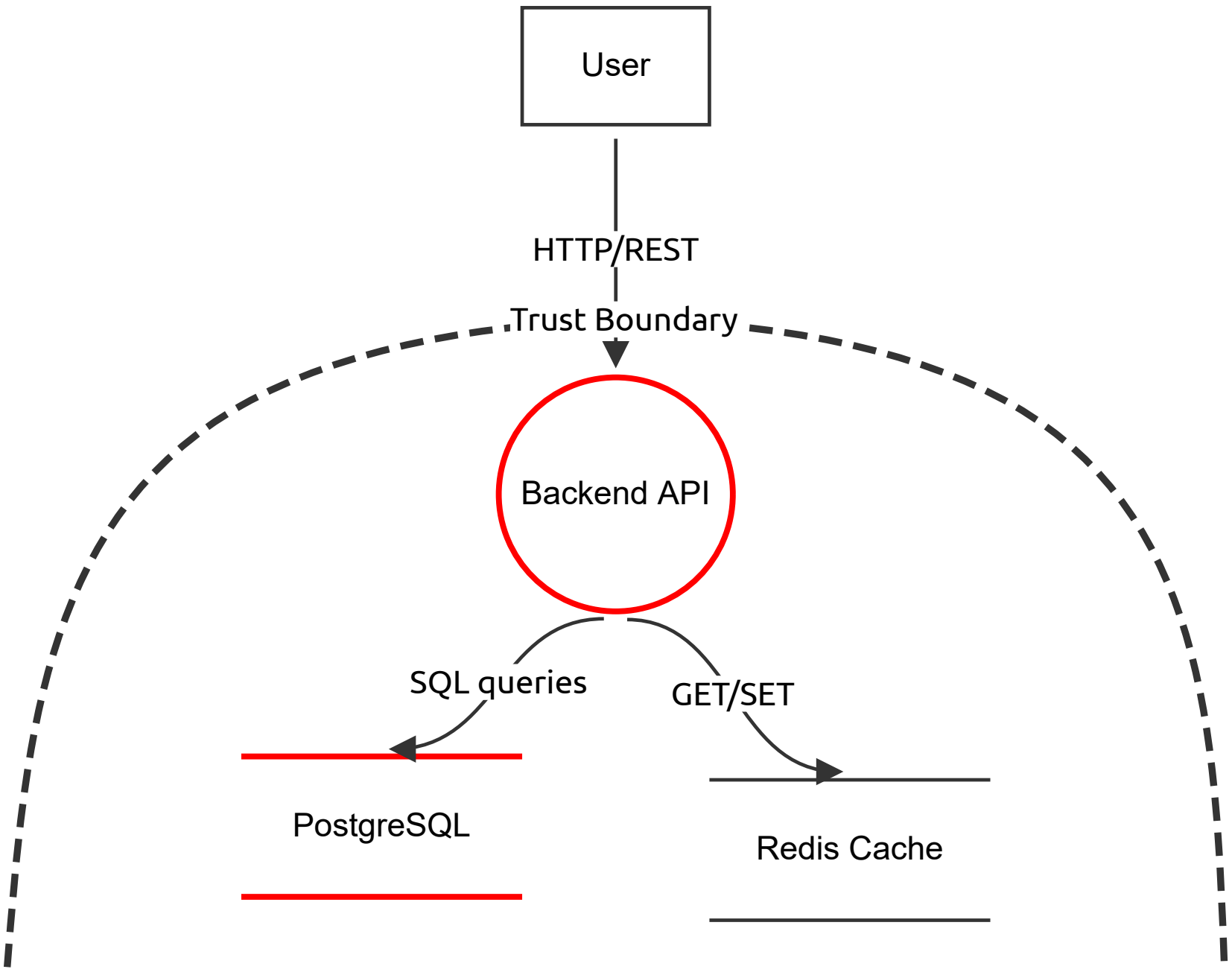
High level system description

A service exposing an HTTP/REST API for processing user requests.
The backend API interacts with a PostgreSQL database for persistent data storage and Redis for caching.

Summary

Total Threats	6
Total Mitigated	0
Total Open	6
Open / Critical Severity	0
Open / High Severity	5
Open / Medium Severity	1
Open / Low Severity	0

Bank Service Data Flow Diagram



Bank Service Data Flow Diagram

User (Actor)

Description: External user interacting with the microservice through the API.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Backend API (Process)

Description: Backend microservice exposing HTTP/REST API and processing user requests

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Unauthorized user impersonation	Spoofing	High	Open		An attacker may impersonate a legitimate user and access the Backend API using stolen or forged authentication credentials or tokens	Use strong authentication, secure session management and token validation. Enforce authorization checks for every protected API operation
5	Insufficient audit logging	Repudiation	Medium	Open		A user or attacker may perform actions through the Backend API without sufficient audit logging, making it difficult to determine who performed an operation or reconstruct security-relevant events	Implement comprehensive audit logging for authentication, authorization and sensitive operations. Include user identity, timestamp, source information and operation details. Protect logs from unauthorized modification
7	Backend API resource exhaustion	Denial of service	High	Open		An attacker may send a large number of requests or specially crafted requests to the Backend API, exhausting server resources and preventing legitimate users from accessing the application	Implement rate limiting and request throttling. Validate request size and complexity, apply appropriate timeouts and monitor resource consumption. Use infrastructure-level protections against excessive traffic
8	Privilege escalation through insufficient authorization	Elevation of privilege	High	Open		An attacker may exploit insufficient authorization checks in the Backend API to access functionality or data belonging to users with higher privileges	Enforce server-side authorization checks for every protected operation. Apply role-based or attribute-based access control and follow the principle of least privilege. Do not rely on client-side authorization controls

PostgreSQL (Store)

Description: Persistent application data stored in PostgreSQL

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Unauthorized modification of database data	Tampering	High	Open		An attacker may modify, insert or delete application data in PostgreSQL by exploiting a vulnerability in the Backend API or gaining unauthorized database access. This could compromise the integrity of stored data	Use parameterized SQL queries and strict input validation. Apply least-privilege database permissions and restrict direct database access. Monitor and audit database operations

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Sensitive data disclosure from database	Information disclosure	High	Open		An attacker may gain unauthorized access to sensitive information stored in PostgreSQL through an application vulnerability, excessive database privileges or unauthorized database access	Apply least-privilege access controls and restrict database access to authorized services. Encrypt sensitive data where appropriate and protect database credentials. Prevent sensitive data from being exposed through API responses or error messages

Redis Cache (Store)

Description: Redis cache used for temporary application data

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTP/REST (Data Flow)

Description: User request sent to the backend API over HTTP/REST

Number	Title	Type	Severity	Status	Score	Description	Mitigations

SQL queries (Data Flow)

Description: SQL queries between the backend API and PostgreSQL database

Number	Title	Type	Severity	Status	Score	Description	Mitigations

GET/SET (Data Flow)

Description: GET and SET operations between the backend API and Redis cache

Number	Title	Type	Severity	Status	Score	Description	Mitigations